

Drum pruefe was in der Cloud sich alles findet ueber Confidential Computing

CISO, ISM ISO27001 IT-Security Auditor ISO 19011

December 21, 2025

- Was ist vertrauliches Computing?
- Wie vertrauliche Computer funktionieren
- Warum ist vertrauliches Computing eine bahnbrechende Technologie?
- Das vertrauliche Computing-Konsortium
- Funktionsweise von Confidential Computing
- Vergleich mit anderen Ansätzen zur Verbesserung des Datenschutzes
- Vorteile und Herausforderungen
- Referenzen

Abkürzungen

- IT Informationstechnologie
- SEV Secure Encrypted Virtualization
- SEV-ES SEV Encrypted State
- SEV-SNP SEV Secure Nested Paging
- SGX Software Guard Extensions
- TCB Trusted Computing Base
- TCG Trusted Computing Group
- TEE Trusted Execution Environment
- TPM Trusted Platform Module
- VM Virtuelle Maschine

stellen Sie sich bitte einmal folgende Situation vor
Sie arbeiten für einen großen Gesundheitsdienstleister

- Sie verfügen über Patientendaten, die in der Cloud verarbeitet werden müssen.
- Sie müssen sicherstellen, dass niemand, einschließlich des Cloud-Anbieters selbst, auf diese Daten zugreifen oder sie manipulieren kann. (DSGVO)
- **Wie können Sie sicher sein, dass der Cloud-Server sicher ist, bevor Sie sensible Informationen an ihn senden?**

Hier kommt die Remote-Attestation ins Spiel.

Sie ist wie eine virtuelle Sicherheitskontrolle, die sicherstellt, dass die Umgebung, in der Ihre Daten verarbeitet werden, vertrauenswürdig ist."

Es gibt drei Zustände, in denen sich Daten befinden können: in der Speicherung (z.B. auf der Festplatte), in der Übertragung und in der Nutzung. Bisher war es nicht möglich, Daten während der Nutzung zu verschlüsseln. Confidential Computing ändert dies, sodass Daten sogar zur Laufzeit im Arbeitsspeicher verschlüsselt bleiben. - <https://www.edgeless.systems/de/confidential-computing>

Confidential Computing ist ein neues Paradigma zum Schutz von Programmcode und Daten während der Ausführung. Erreicht wird dies durch neuartige Hardware-Erweiterungen, die eine Etablierung von Trusted Execution Environments ermöglichen. Solche vertrauenswürdigen Ausführungsumgebungen sind gegenüber der Umgebung vor unberechtigtem Zugriff, z.B. durch privilegierte Systemsoftware-Schichten und Systemadministratoren, geschützt.

- <https://sys.cs.fau.de/research/fields/confidential-computing>

*Immer mehr Unternehmen setzen auf Hybrid- und Public-Cloud-Dienste, was es wichtiger denn je macht, Datenschutzlösungen zu finden. Das Hauptziel des vertraulichen Computings besteht darin, Unternehmen ein größeres Vertrauen in die Sicherheit ihrer Daten und den Schutz von Kundendaten zu geben. Sie **müssen** wissen, dass es gut geschützt und vertraulich ist, **bevor** sie es in eine Cloud-Umgebung verlagern können. - <https://www.fortinet.com/de/resources/cyberglossary/confidential-computing>*

Was ist Remote Attestation?

Definition

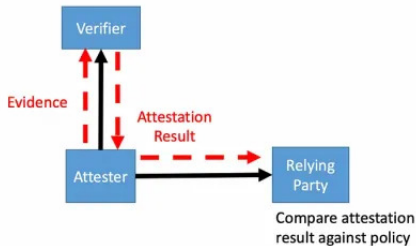
Die Fernbescheinigung trennt die Erstellung von Nachweisen von deren Überprüfung, dass beispielsweise ein Bescheinigungsserver (AS) dynamisch auf Situationen wie die Entdeckung neuer Schwachstellen reagieren und eine zuvor akzeptierte Konfiguration ablehnen kann. Ein physischer Chip wie ein Trusted Platform Module (TPM) kann nur sehr begrenzte Richtlinien durchsetzen. Die Verwendung eines Remote-Servers ermöglicht eine viel umfassendere Richtlinienüberprüfung sowie nahezu Echtzeit-Updates für neue Schwachstellen.

Definition

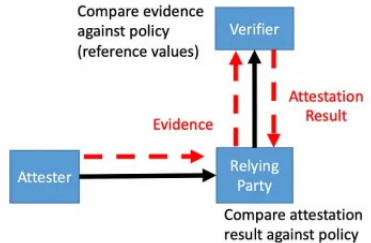
Es können zwei unterschiedliche Attestierungsmodelle verwendet werden, das sogenannte Passmodell und das Hintergrundprüfungsmodell:

- Beim Passmodell validiert der Attestierende vorab ein Identifikationstoken mit dem Verifizierenden - Äquivalent ist die Vorlage Ihres Reisepasses.
- Beim Hintergrundprüfungsmodell fordert die vertrauende Partei eine Überprüfung an, wenn der Attestierende seine Nachweise vorlegt - Äquivalent wäre die Überprüfung biometrischer Messungen

“Passport” model:



“Background check” model:



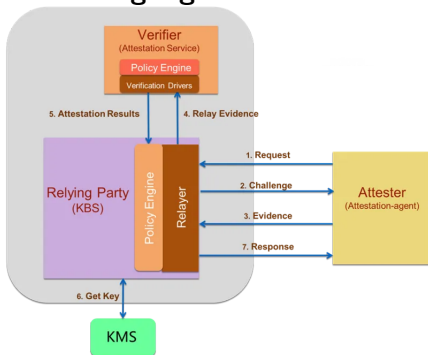
Die kryptografische Verifizierung eignet sich im Allgemeinen eher für ein Hintergrundprüfungsmodell als für ein Passmodell. Dies ist in der Regel sinnvoller, insbesondere weil es die Möglichkeit bietet, den Zugriff jederzeit zu widerrufen.

Komponenten für die Fernbeglaubigung

- Ein Beglaubigungsserver (AS), der die virtuelle Maschine einer kryptografischen Überprüfung unterzieht, um die als Nachweis vorgelegte Messung zu validieren.*
- Ein Attestierungsclient (AC), über den der Attestierende Beweise an einen Attestierungsserver senden kann.
- Ein Key Broker Service (KBS) speichert Geheimnisse wie Festplattenverschlüsselungsschlüssel und gibt sie nur bei erfolgreicher Verifizierung frei. Dieser KBS kann Teil eines größeren Schlüsselverwaltungssystems (KMS) sein. Ein Key Broker Client (KBC) empfängt die Schlüssel vom KBS im Namen des Attestierenden.

Beachten Sie, dass sich der Teil der Schlüsselvermittlung konzeptionell von der Beglaubigung selbst unterscheidet, ohne notwendigerweise Schlüsselvermittlungsdienste anzubieten. Im Falle von vertraulichem Computing ist der Beglaubigungsdienst jedoch in der Regel nicht dafür gedacht, dass Menschen die Konformität ihres Bestands überprüfen, sondern wird zu einem integralen Bestandteil der Vertraulichkeitsgarantie, in der Regel durch die Übermittlung von Geheimnissen.

Das folgende Diagramm zeigt ein Beispiel für den Bescheinigungsablauf bei vertraulichem Computing:



- Der Bescheinigende sendet eine Anfrage an den Bescheinigungsserver.
- Der Server antwortet mit einer Herausforderung, die in der Regel einen Nonce* enthält, um Replay-Angriffe zu vermeiden.
- Der Attester reicht seine Beweise ein, die Elemente der Herausforderung mit vom Attester bereitgestellten Daten kombinieren, sodass das Ergebnis weder von Dritten reproduziert noch von anderen Personen als dem Urheber der Herausforderung verwendet werden kann, um Man-in-the-Middle-Angriffe zu blockieren.
- Der Beglaubigungsserver enthält einen Verifizierer, der verschiedene Richtlinien anwendet.**
- War die Beglaubigung erfolgreich, wird der Schlüsselvermittlungsdienst angewiesen, die Schlüssel für diesen bestimmten Beglaubigten freizugeben.
- Die Schlüssel werden in einer Antwort gepackt, die der KBC im Beglaubigten verarbeiten kann.

* In der Kryptografie ist ein Nonce eine beliebige Zahl, die nur einmal in einer kryptografischen Kommunikation verwendet werden kann.

Technolgie	Prozessor	Codename
AMD Secure En- cryptd SEV	Untervorbehalt: EPYC 2 ES	ROME
Virtualization (SEV)	EPYC 3 (SEV SNP) or later	MILAN
Intel Trusted Do- main Extension TDX	4th Gen Xeon or related	SAPPHIRE RAPIDS
Architecture (CCA)	ARM Cortex A9	FALCON
NVIDIA Confiden- tial Computing	NVIDIA H100 GPU	HOPPER
IBM Secure Exe- cution for Linux	IBM z15 or later	
		IBM LinuxONE III

Das Datenverschlüsselungskonzept ist für Cloud Computing nicht neu.

*Beim vertraulichen Computing werden jedoch neben Daten, die sich im Ruhezustand befinden und übertragen werden, **auch die verwendeten Daten** durch Verschlüsselung geschützt.*

Wie vertrauliche Computer funktionieren

Das Problem

Bevor eine Anwendung Daten verarbeiten kann, muss sie im Speicher entschlüsselt werden. *Hierbei sind die Daten für einen Moment unverschlüsselt, d.h.sie bleiben offen. Sie können darauf zugreifen direkt vor, während und direkt nach der Verarbeitung.*

*Das macht Bedrohungen wie Speicher-Dump-Angriffe (**Schnappschuss des Speichers**) auch als cold-boot-attack möglich. Der Angreifer löst diesen Fehler als Teil des Angriffs aus und zwingt die Offenlegung der Daten. (Daten sind auch Root-Benutzer-Kompromittierungen ausgesetzt, die auftreten, wenn die falsche Person Zugriff auf Administratorrechte erhält und daher vor, während und nach ihrer Verarbeitung auf Daten zugreifen kann.)*

Die Loesung

Trusted Computing behebt dieses Problem mit einer hardwarebasierten Architektur, die als **vertrauenswürdige Ausführungsumgebung** (Trusted Execution Environment, TEE) **ein sicherer Coprozessor innerhalb einer CPU** bezeichnet wird.

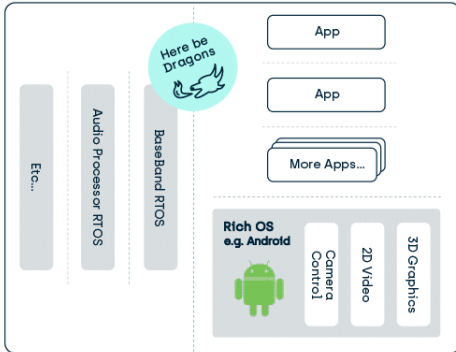
Was ist eine vertrauenswürdige Ausführungsumgebung (TEE)?

Definition

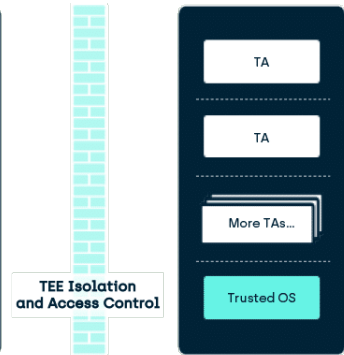
eine Umgebung zur Ausführung von Code, in der diejenigen, die den Code ausführen, ein hohes Maß an Vertrauen in die Umgebung haben können, da sie Bedrohungen aus dem Rest des Geräts ignorieren kann.

Anwendungen in der TEE als Trusted Applications werden (TAs) bezeichnet. Der Rest des Geräts enthält ein funktionsreiches Betriebssystem und wird in diesem Zusammenhang als REE (Rich Operating System Execution Environment) bezeichnet.

Normal World aka REE



Secure World aka TEE



New applications in the TEE are validated before installation

And again validated for consistency before execution.

Enklaven

Definition

Eine Enklave ist, eine isolierte Umgebung innerhalb eines Prozessors. Operationen können sicher darin ablaufen, sodass die zu verarbeitenden Daten geschützt sind. Ein wesentliches Merkmal ist dabei die Isolation: **Enklaven sind konsequent von den anderen Teilen des Systems getrennt**, die wiederum nur über bestimmte sichere Schnittstellen mit ihnen kommunizieren können. Zudem werden starke kryptografische Technologien verwendet, um die Daten innerhalb der Enklave zu verschlüsseln. Isolation und Verschlüsselung stellen sicher, dass Daten in einer solchen Ausführungsumgebung vor nicht autorisierten Zugriffen geschützt sind.

Confidential Computing setzt auf die Verschlüsselung des Arbeitsspeichers von virtuellen Maschinen. Diese Umgebungen werden auch Enklaven beziehungsweise Trusted Execution Environments (TEEs) genannt

Vertrauen in eine vertrauenswürdige Ausführungsumgebung (TEE)

*In der TEE bedeutet "**Vertrauen**", dass Sie ein höheres Maß an Vertrauen in die Gültigkeit, Isolation und Zugriffskontrolle von Elementen (Assets) haben dürfen, die in diesem Bereich gespeichert sind, als in allgemeineren Softwareumgebungen.*

Warum ist eine TEE Ausführungsumgebung vertrauenswürdiger?

- sicherer Start

Definition

In der TEE erfordert dieses Vertrauen, dass alle TEE-bezogenen Assets, der Code, das zugrunde liegende vertrauenswürdige Betriebssystem und dessen Support-Code installiert und gestartet wurden.

- Methodik

Definition

verlangt, dass der Ausgangszustand den Erwartungen der Entwickler entspricht (d. h. **ALLES** wird auf Signaturen überprüft, ist unveränderlich oder isoliert gehalten).

TEEs akzeptieren nur Code zur Ausführung, der:

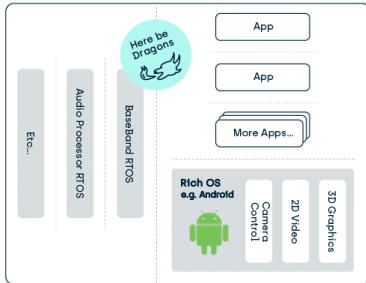
- entsprechend autorisiert wurde
- durch anderen autorisierten Code überprüft wurde

Dies umfasst alles nach dem ROMii-Bootvorgang (der ROM-Code kann aufgrund seiner Präsenz als autorisiert betrachtet werden). TAs können nur direkt auf ihre eigenen Daten (einschließlich Schlüssel) zugreifen: **Es gibt keine Methode, mit der eine TA direkt auf Assets anderer TAs oder anderer Komponenten der TEE zugreifen kann.**

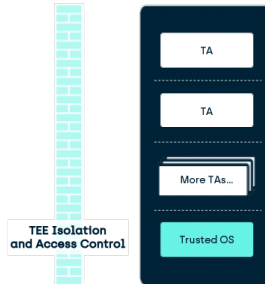
Beachten Sie, dass sich dies deutlich vom ursprünglichen Trusted-Computing-Modell unterscheidet, bei dem jeder Code ausgeführt werden konnte, dieser Code jedoch nach dem Booten durch entfernte Entitäten potenziell überprüfbar war. Dieses Modell funktioniert nicht so gut bei Geräten, bei denen der lokale Benutzer ein gewisses Maß an Vertrauen wünscht, ohne Bezugnahme auf eine externe Entität.

Laufzeitisolierung

Normal World aka REE



Secure World aka TEE



New applications in the TEE are validated before installation

And again validated for consistency before execution.

Die Signaturprüfung während der Installation, des Bootvorgangs und des Ladens von Material ist großartig, aber ... was geschah 1 Sekunde später?

- Um das Vertrauen aufrechtzuerhalten, müssen wir Eingriffe in den ausführenden Code und seine Ressourcen zur Laufzeit unterbinden.
- TEE sorgt für eine Isolierung zwischen den vertrauenswürdigen Anwendungen und anderen Ressourcen innerhalb der TEE.
- Eine bestimmte vertrauenswürdige Anwendung (TA) im TEE muss nur dem vertrauenswürdigen Betriebssystem vertrauen und muss sich nicht darum kümmern, welche anderen TAs im TEE vorhanden sind.
- Die Benutzer der TEE-basierten Software können darauf vertrauen, dass ihre Ressourcen nicht ohne Genehmigung offengelegt, geändert oder gelöscht werden können

Beispiel für Isolierung

Definition

Eine TA hat keine Möglichkeit, eine Datei zu öffnen, die einer anderen TA gehört

- Wenn TA1 eine Datei mit dem Namen *Secrets* erstellt, kann TA2 ebenfalls eine Datei mit dem Namen *Secrets* erstellen
- das vertrauenswürdige Betriebssystem behandelt sie als zwei verschiedene Dateien
- TA2 kann mit seiner Datei tun, was sie will - sie kann keine Änderungen an der Datei von TA1 vornehmen.
- Nichts im REE kann auf den Inhalt der Datei einer der beiden TAs zugreifen

Ein Angreifer koennte nicht einmal manuell die Assets eines TA zwischen Geräten kopieren, um zu versuchen, die TEE-Sicherheit zu umgehen, da der TEE-Speicher vollständig an das Gerät gebunden ist.

Sovereign Cloud Stack (SCS)

- von der Open Source Business Alliance (OSBA) entwickelt
- stellt eine offene, standardisierte und vollständig auf Open-Source-Technologien basierende Cloud-Infrastruktur dar
- Ziel ist es, eine europäische Cloud-Lösung zu schaffen, die höchsten Anforderungen an Sicherheit, Skalierbarkeit und Transparenz gerecht wird

BSI C 5

Definition

C5 ist ein Kriterienkatalog, der ein grundlegendes Sicherheitsniveau für Cloud-Dienste festlegt. Er zielt darauf ab, die Informationssicherheit auf der Grundlage einer standardisierten Prüfung und eines standardisierten Berichts auf transparente Weise darzustellen. Kunden bewerten diese Berichte im Rahmen ihrer eigenen Risikoanalyse.

- Der C5-Anforderungskatalog wurde erstmals im Jahr 2016 veröffentlicht und 2020 ergänzt
- ist kein zusätzlicher Standard
- bündelt unterschiedlichste Prüfschemata, Richtlinien und ergänzt diese
- Dadurch werden Mehrfachprüfungen einzelner Anforderungen vermieden und der Gesamtaufwand für einen Audit reduziert

Die Unterschiede zwischen BSI C5 Typ 1 und BSI C5 Typ 2

Definition

der BSI C5-Standard ist kein statisches Prüfschema, sondern in zwei Typen unterteilt:

- Typ 1 bescheinigt dem Cloud-Dienstleister ein angemessenes Sicherheitsmanagement **zum Zeitpunkt des Audits**.
- Typ 2 dagegen zielt auf die fortlaufende Wirksamkeit der Sicherheitsmaßnahmen im Prüfungszeitraum (üblicherweise sechs bis zwölf Monate)

Das Typ 2-Testat kann dabei nicht ohne eine initial durchlaufene Typ 1-Auditierung erworben werden.

Referenzen

- <http://globalplatform.org/specs-library/tee-management-framework-v1/>
- <http://globalplatform.org/specs-library/tee-client-api-specification/>
- <http://globalplatform.org/specs-library/tee-protection-profile-v1-2-1/>
- <http://globalplatform.org/specs-library/globalplatform-technology-tee-trusted-user-interface-low-level-api-v1-0-1/>
- <http://globalplatform.org/specs-library/tee-internal-core-api-specification-v1-2/>
- <http://globalplatform.org/specs-library/tee-system-architecture-v1-2/>